

Physical Insider Threat — Weeks 1–3

Week 1 — Cyber Threat Intelligence Fundamentals

Glossary of key terms

- **Insider threat** — risk posed by someone with authorized access (employee, contractor, vendor) who misuses that access, intentionally or not.
- **Physical insider threat** — insider threat expressed through physical means (access to buildings, devices, hardware) rather than purely digital access.
- **Tailgating / piggybacking** — following an authorized person through a secured door without using your own credentials; piggybacking implies the authorized person knowingly lets you in.
- **Badge cloning** — copying the data from an RFID/NFC access badge onto a blank card to impersonate the legitimate holder.
- **USB drop attack** — leaving a malicious USB device in a place an employee is likely to find and plug in (parking lot, break room, lobby).
- **Shoulder surfing** — observing someone entering credentials or PINs, or viewing sensitive screens, in person.
- **Social engineering (physical)** — manipulating staff face-to-face (posing as delivery, IT support, a new hire) to gain access or information.
- **Access control system (ACS) / СКУД** — the badge/biometric system that logs and controls physical entry to a facility.
- **Dwell time** — how long an unauthorized person remains undetected inside a facility after gaining access.
- **Negligent insider** — an employee who causes harm unintentionally (e.g., leaves a door propped open, loses a badge).
- **Malicious insider** — an employee who intentionally misuses physical access to cause harm or exfiltrate assets.
- **Compromised insider** — a legitimate employee whose credentials/badge/access is being used by someone else without their knowledge.

Classification of threat types and sources

Category	Source	Example
Negligent	Employee	Propping open a secure door, losing a badge
Malicious	Employee/contractor	Stealing hardware, deliberately letting an outsider in
Compromised	External actor via employee	Cloned badge, stolen credentials used by a third party
Third-party	Vendor/delivery/cleaning staff	Misusing legitimate temporary access

Recommended reading (per syllabus): ENISA Threat Landscape Report — pull out whatever it says about insider/physical vectors as a citation base for the glossary.

Week 2 — Data Collection Process

OSINT case studies (public, physical insider-threat incidents)

Pick 2–3 of these to write up in `/case-studies` :

- A known case of an employee smuggling out hardware or storage media containing sensitive data.
- A documented penetration-test writeup where testers successfully tailgated into a secure facility (many pentest firms publish these as blog case studies — search "physical penetration test tailgating case study").
- A vendor/contractor abuse case — someone with legitimate but limited physical access (cleaning crew, delivery, temp IT support) exceeding it.

For each, capture: what access was abused, how it was discovered (or wasn't, until much later), what controls failed, and what controls would have caught it.

Data source mapping

List where physical-access evidence would actually live in a real org, since there's no "Shodan for badges" — this is the OSINT-equivalent exercise for a physical topic:

- Badge/ACS logs (entry/exit timestamps, door, badge ID)

- CCTV metadata (not footage — just what's logged: camera, timestamp, zone)
- Visitor management system logs (who signed in as a guest, host, purpose)
- HR system (employment status, role, whether someone was recently terminated/resigned)
- Asset inventory (what hardware was checked out to whom)

Week 3 — Data Processing and Exploitation

Indicator table (physical-access equivalent of IOCs)

Since there are no file hashes here, this is a behavioral-indicator table instead:

Indicator	What it suggests
Badge-in with no corresponding badge-out	Tailgating, or badge left with someone else
Access outside normal working hours/shift	Unauthorized use, possible compromised badge
Access to a zone outside the person's role	Privilege misuse or badge cloning
Two badge-ins for the same badge ID within an implausible time window at different doors	Cloned badge in use
Asset checked out but never returned, no exit interview flag	Hardware theft
Spike in visitor sign-ins by one host in a short period	Possible social-engineering pretext being tested

Filtering/normalization approach

- Normalize timestamps to a single timezone across ACS, visitor log, and HR data.
- Filter out expected patterns first (normal shift hours, known contractor schedules) so anomalies stand out.
- Cross-reference badge ID → employee ID → HR status to catch access still active after termination.

Recommended reading (per syllabus): MISP Training Documentation — even though MISP is built for cyber IOCs, the same tagging/correlation logic applies here; worth noting in the repo that you adapted a cyber tool's methodology to a physical-security dataset.